Semana 07 — Desarrollo seguro y cadena de suministro

Fase 3: Defensa y hardening — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	07 de 10
Fase	3 — Defensa y hardening
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Control de fase 3
Entrega	GitHub, carpeta semana_07/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Comprobar que el repositorio del grupo tiene la carpeta semana_07 creada.
2. Revisar la retroalimentación del docente sobre la semana anterior y corregir lo pendiente.
3. Traer instaladas las herramientas de la semana: bandit, pip-audit, DVWA editado.
4. Confirmar que el laboratorio arranca y que los tres servicios responden antes de la sesión.
5. Leer el objetivo y los contenidos para llegar con el vocabulario de la práctica.

2 Objetivo de la semana

Corregir vulnerabilidades en código y demostrar la mitigación repitiendo el mismo payload, con controles automatizados en la cadena de suministro.

3 Contenidos que se aplican

- Validación de entrada y salida, parametrización de consultas.
- Codificación de salida, CSP y cabeceras de seguridad.
- Gestión de dependencias, SBOM y pip-audit.
- Análisis estático con bandit y escaneo de secretos.
- Revisión de código y criterios de aceptación de seguridad.

4 Escenario

Cada grupo corrige tres vulnerabilidades de la semana 5 en su copia del laboratorio y demuestra que el payload original ya no funciona.

5 Paso a paso de la práctica

1. Reproducir los tres hallazgos sobre la copia sin parchear y guardar la evidencia.
2. Aplicar la corrección con parametrización, codificación de salida y validación.
3. Repetir exactamente el mismo payload y documentar el nuevo resultado.
4. Ejecutar bandit, pip-audit y escaneo de secretos, y adjuntar la salida.
5. Escribir el criterio de aceptación de seguridad que impediría la regresión.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_07/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: bandit, pip-audit, DVWA editado.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
Grupo 2	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.
Grupo 3	**Rojo**	Evidencia cruda en semana_07/evidencia y el apartado de reproducción del informe.
Grupo 4	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.

7 Qué se entrega

Parches, evidencia antes y después con el mismo payload, y salida de los tres controles.

Estructura de la carpeta `semana_07/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_07/informe.md o informe.pdf con el entregable de esa práctica.
- semana_07/scripts/ con el código, con type hints y docstrings.
- semana_07/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_07/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Correcciones que eliminan la causa raíz, no el síntoma	3,0
Demostración antes y después con el mismo payload	2,5
Controles automatizados ejecutados e interpretados	2,0
Criterio de aceptación que previene la regresión	1,5
Sin regresiones funcionales en la aplicación	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_07/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit 'semana 07: <entregable>' está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
Validación de entrada	Comprobar tipo, formato, longitud y rango de lo que llega antes de usarlo. No sustituye la parametrización.
Parametrización de consultas	Enviar los datos como parámetros separados de la sentencia, de modo que no puedan alterar su estructura.
CSP	Cabecera que restringe desde dónde puede cargar recursos la página y mitiga XSS. No repara una salida sin codificar.
SBOM	Inventario de componentes y versiones de un producto. Permite responder qué dependencia está afectada por una vulnerabilidad.
Análisis estático	Revisar código sin ejecutarlo para encontrar patrones inseguros. Es rápido y repetible, pero produce falsos positivos.
Cabeceras de seguridad	Respuestas HTTP como HSTS, X-Content-Type-Options o Referrer-Policy que reducen la superficie del navegador.